

Segurança e Privacidade

ASSIGNMENT #2: Privacy Impact Assessment

Alunos: André Chen Xie, Beatriz Morais Vieira, Manuel Henrique da Silva Mota

Licenciatura: Inteligência Artificial e Ciências de Dados

Data: 4 de maio de 2026

1. Introdução

O presente relatório tem como objetivo a realização de uma Avaliação de Impacto sobre a Proteção de Dados (PIA - *Privacy Impact Assessment*) para o projeto de investigação COP-MODE. Este projeto foca-se na análise das decisões de privacidade dos utilizadores em dispositivos móveis, recorrendo a campanhas de recolha de dados "in-the-wild" durante períodos de uma semana.

A execução de um PIA é um passo crítico na metodologia de *Privacy by Design*, permitindo identificar, avaliar e mitigar riscos para a privacidade dos titulares dos dados antes e durante o ciclo de vida do sistema.

Este documento descreve detalhadamente o fluxo de informação entre os participantes e os servidores da instituição, avalia os riscos inerentes a um cenário de configuração base e propõe um plano de ação corretivo. Finalmente, é apresentada uma avaliação dos riscos após a aplicação de mecanismos de segurança, como criptografia e anonimização, demonstrando a evolução do nível de proteção dos dados pessoais envolvidos no projeto.

2. Descrição e Avaliação do Sistema

2.1 - Visão Geral do Projeto (COP-MODE)

O objetivo central do projeto COP-MODE é investigar, no âmbito da privacidade e segurança em dispositivos móveis, as intenções e comportamentos reais dos utilizadores ("*privacy intention in-the-wild*") perante pedidos de permissões de aplicações no sistema Android.

A campanha inicia-se com a instalação da aplicação CM-AR (Apps Retriever) no seu smartphone pessoal, que recolhe o inventário das aplicações instaladas e solicita o consentimento para o estudo. A seguir, com base na lista de aplicações do voluntário, a equipa do COP-MODE configura um smartphone de campanha (fornecido pela equipa) com essas mesmas aplicações e a ferramenta CM-NPM, responsável pela monitorização contínua do dispositivo.

Assim, durante o período de 1 semana, o utilizador usa o smartphone de campanha como o seu dispositivo principal, sendo que durante este tempo, a aplicação CM-NPM interceta pedidos de permissões sensíveis ("*dangerous permissions*") e regista a decisão do utilizador (conceder ou negar), juntamente com o contexto do dispositivo. Além disso, o sistema também armazena informações variadas relativas aos utilizadores. Todos os dados recolhidos são enviados de forma contínua para o servidor central do COP-MODE para posterior análise dos investigadores.

Por fim, a campanha termina com a devolução do smartphone fornecido e eliminação do email, seguindo-se a investigação dos resultados.

2.2 – Entidades Envolvidas

PII Principals (titulares dos dados/data subjects): Voluntários maiores de 18 anos, utilizadores de Android, que utilizam o dispositivo de campanha como o seu smartphone principal. Demograficamente, a amostra caracteriza-se por uma forte prevalência de jovens adultos (71% entre 18 e 24 anos) com background na área de Tecnologias de Informação (57%).

PII Controllers e Processors: Equipa de investigação do COP-MODE. Todos os dados recolhidos são guardados e tratados exclusivamente por esta equipa nos servidores da Universidade de Coimbra.

Third Parties (Terceiros): Investigadores externos à equipa principal, aos quais poderá ser cedido acesso apenas a uma versão estritamente anonimizada e incompleta do dataset final para fins científicos.

2.3 – Dados Pessoais Recolhidos

A organização e o tratamento dos dados no projeto COP-MODE baseiam-se na sensibilidade dos mesmos, definindo o acesso e as medidas aplicadas a cada categoria de informação pessoal (PII). No primeiro nível, encontram-se os dados estritamente internos e de acesso restrito, que nunca são partilhados com entidades externas (como investigadores):

- **Identificadores diretos:** endereço de e-mail do participante, utilizado exclusivamente como meio de contacto e gestão da devolução dos smartphones, sendo eliminado de imediato após a conclusão da campanha para garantir a anonimização do dataset. E o inventário inicial de aplicações recolhido pela app CM-AR, isto é, a lista completa de apps instaladas no smartphone pessoal do voluntário, recolhida pela app CM-AR para configurar o dispositivo de teste.
- **Dados de monitorização contínua altamente intrusivos:** nomeadamente a localização geográfica exata via GPS, os identificadores de dispositivos Bluetooth e redes Wi-Fi na proximidade do utilizador, além dos metadados de calendário, que se limitam a IDs de eventos e horários para preservar a privacidade do conteúdo das marcações.

Numa segunda categoria situam-se os dados de contexto e comportamento, que constituem a informação partilhável com investigadores externos, mas apenas após um rigoroso processo de anonimização irreversível:

- **Estado e conectividade do dispositivo:** tipo de conectividade, isto é, se o smartphone utiliza redes Wi-Fi ou 4G/5G, bem como o seu estado de atividade, distinguindo entre períodos de inatividade, uso geral ou chamadas de voz.
- **Logs de Decisão de Permissões (Interceção CM-NPM):** detalham o nome, versão e categoria da aplicação (que solicita o acesso), a visibilidade das apps em primeiro e segundo plano, e o resultado da interação, ou seja, se o utilizador optou por conceder ou negar a permissão solicitada.

Mapeamento dos dados recolhidos:

Tipo de Dados	Sensibilidade	Observação
Endereço de email	Máxima	Identificador pessoal, usado para contacto e é eliminado após a campanha.
Localização de GPS exata	Elevada	Rastreio exato e contínuo de todos os movimentos do utilizador.
Atividades no Calendário	Elevada	Revela a agenda e os compromissos privados (horas e locais).
Lista de apps instaladas	Elevada	Permite ter acesso a um perfil detalhado de interesses e hábitos pessoais.
Identificadores de rede	Elevada	Identificadores (Wi-Fi) que permitem deduzir a localização.
Estado/Conectividade	Média/Baixa	Indica se o telemóvel está em uso e que tipo de internet utiliza.
Logs Decisão de Permissões	Média	Registo da decisão do utilizador (aceitar/negar acesso)
Informação da Aplicação	Média	Nome, tipo e outras características da aplicação requerente

2.4 – Fluxo de Dados

O projeto COP-MODE inicia-se com a fase de Recrutamento e Consentimento. Nesta etapa, o titular dos dados (participante) instala a aplicação *COP-MODE Apps Retriever* (CM-AR) no seu dispositivo pessoal. Mediante o consentimento, a aplicação recolhe e transmite para o servidor do projeto o endereço de e-mail do utilizador, a data de consentimento e o inventário completo das aplicações instaladas, incluindo as respetivas definições de permissão. O e-mail funciona como o identificador primário necessário para a gestão da campanha e comunicação direta com o participante.

Seguidamente, ocorre a Configuração e Entrega do Equipamento, na qual a equipa instala as aplicações recolhidas, além do CM-NPM, num smartphone da campanha. No momento da entrega física do dispositivo, o fluxo de dados é formalizado juridicamente através da assinatura do Acordo de Coleta de Dados, que estabelece os termos de utilização e as garantias de privacidade.

A fase mais crítica de processamento é a Recolha Ativa de Dados, que decorre durante 1 semana de utilização do smartphone de campanha como dispositivo principal. Neste período, a CM-NPM atua como um intermediário ativo, intercetando todos os pedidos de "permissões perigosas" feitos pelas aplicações. Quando um pedido ocorre, o sistema solicita uma decisão ao utilizador (permitir ou negar o acesso aos dados), armazenando essa resposta em cache durante 30 minutos para mitigar a fadiga de decisão e melhorar a experiência de uso. Simultaneamente, o sistema recolhe e envia para o servidor um conjunto rico de dados contextuais, que incluem a localização geográfica precisa, identificadores de dispositivos próximos (Bluetooth e Wi-Fi), o estado do dispositivo e detalhes de eventos de calendário.

O fluxo encerra-se com o Fim da Campanha e a respetiva Anonimização. Após a devolução do smartphone, a equipa procede à eliminação imediata do endereço de e-mail da base de dados ativa. Este passo é fundamental para a estratégia de privacidade do projeto, pois, ao remover o identificador pessoal, os restantes dados de contexto e as decisões de permissão tornam-se efetivamente anonimizados, impedindo a ligação direta entre os registos no servidor e a identidade real do participante.

Finalmente, existe um fluxo residual de Partilha e Direito ao Apagamento. O *dataset* higienizado — que contém apenas dados de conectividade, contexto e decisões de permissão — pode ser partilhado com parceiros académicos para fins exclusivos de investigação científica. Contudo, conforme o Acordo assinado, o participante pode contactar a equipa a qualquer momento para exigir a eliminação de todos os seus dados. Se o *dataset* já tiver sido partilhado, a equipa reencaminha o pedido aos parceiros académicos, que são obrigados a apagar as respetivas cópias.

3. Avaliação Inicial dos Riscos

3.1 – Definição de Probabilidade e Gravidade

- **Probabilidade (Likelihood):** refere-se à frequência/viabilidade de uma ameaça à privacidade ocorrer através da exploração de uma vulnerabilidade no sistema do COP-MODE.
- **Gravidade (Severity / Impact):** representa a magnitude das consequências para os participantes (Titulares dos Dados) caso um incidente de privacidade ocorra (Ex: fuga de dados ou acesso não autorizado). Neste projeto, a gravidade é influenciada pela sensibilidade dos Dados, uma vez que dados como localização geográfica exata, entradas de calendário e nomes de aplicações são considerados altamente sensíveis, permitindo traçar um perfil detalhado da vida privada do utilizador. É ainda afetada pelo potencial de reidentificação, ou seja, se o endereço de e-mail (armazenado até ao fim da campanha) for exposto juntamente com os dados de localização, o impacto é máximo, pois permite identificar diretamente o indivíduo. Finalmente é necessário analisar os danos ao Titular, já que uma fuga pode resultar em danos morais, perseguição ou uso indevido de hábitos pessoais por terceiros.

NOTA: a gravidade e probabilidade serão avaliadas numa escala crescente de indefinido, insignificante, limitado, significativo e máximo

3.2 - Identificação de Riscos

----- Acesso Ilegítimo dos Dados no Servidor -----

Impactos nos dados dos titulares: A exposição do endereço de e-mail permitiria a identificação direta e inequívoca do titular dos dados. Uma vez estabelecida esta ligação, a revelação do inventário de aplicações instaladas tornar-se-ia um perfil comportamental profundo, capaz de expor hábitos, convicções políticas, orientações religiosas ou estados de saúde, dependendo da natureza das apps utilizadas. Adicionalmente, o acesso indevido comprometeria a segurança física e a liberdade de movimento do indivíduo através da exposição da localização geográfica contínua (seria possível mapear a rotina). Por fim, a exposição dos identificadores de dispositivos em proximidade (Bluetooth e Wi-Fi) permitem inferir relações sociais e frequênciação de locais específicos, mesmo que estes não constem no calendário.

Ameaças principais ao sistema e integridade dos dados: Dados enviados sem cifragem podem ser capturados por atacantes em redes Wi-Fi públicas (*eavesdropping*). Além disso, vulnerabilidades de software, má configuração de rede ou exposição desnecessária à Internet permitem invasões externas. Adicionalmente, o acesso indevido por membros da própria equipa de investigação que não tenham autorização ou que ignorem protocolos de segurança. Por fim, a perda ou roubo dos smartphones de campanha e partilha indevida de dados por parceiros académicos que não cumpram os acordos de confidencialidade.

Fontes de Risco Identificadas: A fonte externa mais evidente provém de atacantes com intenções maliciosas (*hackers*), que poderão tentar invadir o servidor central ou as comunicações. Além do mais, deve-se ainda considerar ameaças internas, como membros da equipa que tentem aceder a dados sensíveis por negligência ou sem autorização. As entidades externas também poderão descumprir os termos de segurança e confidencialidade do acordo de partilha, além dos utilizadores da campanha que poderão explorar o sistema através do acesso físico ao smartphone. Finalmente, falhas técnicas no servidor ou nas aplicações (CM-AR e CM-NPM) facilitariam invasões ou fugas de dados.

Gravidade de risco: Máxima. Os dados recolhidos incluem informação altamente sensível, sendo que um acesso ilegítimo poderia causar danos graves à privacidade dos participantes, incluindo rastreamento físico, discriminação ou dano à reputação. O email, se exposto, permite identificação direta dos titulares e, como mencionado anteriormente, a exposição de dados como os eventos do calendário ou dispositivos e redes próximas poderia expor a rotina e hábitos do utilizador.

Probabilidade de risco: Significativa. O acesso ao servidor é restrito por autenticação forte e firewall, além de não estar diretamente exposto à internet. Os dados são pseudonimizados e o email é eliminado no final da campanha. Contudo, no setup original, os smartphones transmitem dados continuamente para o servidor. Se estas comunicações não forem cifradas, a interceção em redes Wi-Fi públicas é tecnicamente simples.

----- Modificação Indesejada dos Dados -----

Impactos nos dados dos titulares: A principal consequência seria a criação de perfis de utilizador falsos ou distorcidos, resultando em conclusões científicas erradas sobre o comportamento do participante, podendo levar a decisões automatizadas ou inferências de perfil que não correspondem à realidade da sua vida privada. Adicionalmente, este cenário causaria uma perda de confiança dos participantes na integridade do projeto. Ao perceberem que os seus dados e decisões não estão protegidos contra manipulação, os titulares podem sentir que a sua participação é insegura, prejudicando a relação de transparência estabelecida no acordo de coleta de dados.

Ameaças principais ao sistema e integridade dos dados: A ameaça técnica mais significativa é a interceção e alteração de dados durante o envio (ataques *man-in-the-middle*). Caso a comunicação entre os smartphones de campanha e o servidor não seja devidamente protegida, um atacante poderá modificar os dados de contexto ou as decisões de permissão antes de estas serem registadas. Paralelamente, o sistema está exposto a erros humanos ou técnicos no processamento da informação, como falhas em *scripts* ou sistemas no servidor. Tais erros podem levar à corrupção acidental de registos ou à troca de informações entre diferentes participantes, comprometendo a precisão científica necessária para o sucesso do projeto e violando o dever de exatidão dos dados previsto no acordo de coleta.

Fontes de Risco Identificadas: Externamente, hackers e atacantes mal-intencionados podem tentar sabotar a investigação ou alterar registos através de ataques às comunicações. Internamente, o risco reside em investigadores com privilégios excessivos, onde a falta de controlo de acesso facilita modificações acidentais ou deliberadas sem rasto de auditoria. Adicionalmente, parceiros externos que recebam o *dataset* podem manipular os dados sem o devido rigor técnico, gerando resultados inconsistentes que comprometem a validade científica de todo o estudo.

Gravidade de risco: Limitada. Os danos para o titular são maioritariamente informacionais e de confiança, não afetando diretamente a sua integridade física ou financeira de forma grave.

Probabilidade de risco: Significativa. Devido à vulnerabilidade técnica do sistema no envio dos dados.

----- Desaparecimento dos Dados -----

Impactos nos dados dos titulares: O impacto principal é a perda de utilidade do contributo do participante. Além disso, o desaparecimento de fragmentos de informação causa falhas na linha temporal dos hábitos do utilizador, o que prejudica severamente a qualidade da análise final e a precisão do contexto capturado pela aplicação CM-NPM. Do ponto de vista do titular, isto representa uma quebra nas garantias de tratamento adequado dos dados estipuladas no acordo de coleta, invalidando o propósito da sua participação

Ameaças principais ao sistema e integridade dos dados: Falhas de hardware, como avarias críticas nos servidores de alojamento, e erros humanos, como a eliminação acidental de bases de dados. Além disso, ameaças externas como Malware ou Ransomware podem bloquear ou apagar os ficheiros originais. Estas falhas interrompem a investigação e impedem o cumprimento dos deveres de gestão e apagamento de dados prometidos aos participantes.

Fontes de Risco Identificadas: Possíveis fontes de risco poderão ser sistemas de armazenamento desatualizados ou que falhem naturalmente (falta de cópias de segurança), Pessoas com permissões de acesso excessivas que, por falta de supervisão ou formação, cometem erros operacionais, além de hackers que, por malícia ou para sabotar a investigação científica, poderão tentar paralisar o funcionamento do sistema.

Gravidade de risco: Limitada. O desaparecimento de dados não expõe a vida privada do participante a terceiros nem compromete a sua segurança física. O impacto é sentido predominantemente pela equipa de investigação, que perde a utilidade do trabalho realizado e a qualidade da análise.

Probabilidade de risco: Limitada. Sendo o projeto gerido por instituições académicas (Universidade de Coimbra, Porto e Cambridge), pressupõe-se a existência de infraestruturas de TI profissionais com mecanismos básicos de redundância e backups. Erros humanos de eliminação total de bases de dados ou falhas simultâneas de hardware são eventos estatisticamente menos frequentes do que tentativas de acesso externo (hackers) ou interceção de comunicações em redes abertas.

----- Fuga de Dados Através da Interceção de Comunicações (*eavesdropping*) -----

Impactos nos dados dos titulares: A interceção compromete a confidencialidade de dados altamente sensíveis, como a localização geográfica precisa (latitude/longitude) e os dispositivos próximos (Bluetooth/Wi-Fi). Isto permite a um atacante realizar um rastreamento em tempo real do utilizador, expondo a sua rotina diária e segurança física.

Ameaças principais: A ameaça central é o ataque *Man-in-the-Middle* (MitM), especialmente em redes Wi-Fi públicas, onde o atacante se posiciona entre o smartphone e o servidor para capturar o tráfego.

Fontes de Risco: Atacantes externos (hackers) ou proprietários de infraestruturas de rede maliciosas que exploram a ausência de cifragem de canal.

Gravidade de risco: Máxima. Justifica-se pela natureza contínua da recolha de localização e pela capacidade de identificar o contexto social do utilizador através de dispositivos próximos.

Probabilidade de risco: Significativa. No setup inicial (sem cifragem TLS/HTTPS), a interceção de pacotes em redes não fidedignas é tecnicamente simples e provável dado o volume de transmissões ao longo de uma semana.

----- Fuga de Dados por Acesso Não Autorizado ao Servidor -----

Impactos nos dados dos titulares: O impacto é sistémico, resultando na exposição do repositório central que contém e-mails (PII direta), listas de apps, e dados contextuais históricos. Isto permite a criação de perfis invasivos que violam a privacidade prometida no acordo de investigação.

Ameaças principais: Exploração de vulnerabilidades no sistema operativo do servidor ou nos serviços de base de dados, além de falhas na gestão de credenciais administrativas.

Fontes de Risco: Atacantes externos motivados por sabotagem ou roubo de dados, e membros da equipa interna com privilégios de acesso excessivos e não auditados.

Gravidade de risco: Máxima. O servidor é o ponto único de falha; um compromisso aqui anula todas as outras medidas de proteção, expondo dados de todos os participantes simultaneamente.

Probabilidade de risco: Significativa. Justifica-se pela necessidade de o servidor estar acessível remotamente para receber dados dos smartphones, o que aumenta a superfície de ataque.

----- Ligação de Dados em Repouso (Linkage) -----

Impactos nos dados dos titulares: A capacidade de ligar o e-mail (armazenado para fins de comunicação) aos dados de comportamento (localização e apps) elimina a garantia de anonimização final. Terceiros com acesso ao *dataset* poderiam reidentificar indivíduos específicos, expondo a sua vida privada permanentemente.

Ameaças principais: Armazenamento de identificadores diretos (e-mail) e dados contextuais na mesma base de dados sem técnicas de pseudonimização (como hashing) que permitam a separação lógica.

Fontes de Risco: Falhas de arquitetura de dados por parte dos investigadores (PII Controller) e incumprimento de protocolos de segurança por parceiros académicos.

Gravidade de risco: Máxima. A ligação de dados (*linkage*) viola o consentimento informado dos participantes, que esperam a anonimização total após a devolução do smartphone, além de revelar a vida pessoal dos participantes.

Probabilidade de risco: Significativa. Embora exija acesso à base de dados, a ausência de medidas como a proteção do e-mail por cifragem assimétrica ou hashing torna a ligação imediata para qualquer pessoa com acesso ao servidor.

----- Fuga de Informações Sensíveis -----

Nomeadamente nomes de aplicações recolhidos inicialmente

Impactos nos dados dos titulares: Certas aplicações revelam diretamente categorias especiais de dados, como orientação sexual (apps de encontros), estado de saúde (monitores de doenças) ou convicções religiosas. A fuga destes nomes brutos pode levar a discriminação ou estigmatização do participante.

Ameaças principais: Gravação dos nomes das aplicações em formato de texto legível no servidor em vez de identificadores anonimizados que apenas permitam saber se a app é a mesma em diferentes eventos.

Fontes de Risco: Parceiros académicos que recebam dados não sanitizados e investigadores internos sem necessidade de conhecer o conteúdo exato das apps.

Gravidade de risco: Máxima. Se o e-mail for revelado, permite associação com apps, mapeamento da rotina, além da descoberta de aspetos íntimos e sensíveis da personalidade do titular.

Probabilidade de risco: Significativa. No setup básico, a recolha de inventário de apps envia os nomes reais para o servidor para que a equipa possa preparar o smartphone de campanha, tornando os dados vulneráveis desde a origem.

4. Plano de Ação e Medidas Corretivas

Após a avaliação inicial dos riscos referente ao tratamento de dados do projeto, é necessária a implementação de um conjunto de controlos de segurança físicos, lógicos e organizacionais. Este plano de ação tem como objetivo reduzir tanto a probabilidade de ocorrência das ameaças como a gravidade dos seus impactos, garantindo a proteção dos titulares dos dados, ou seja, dos participantes.

NOTA:

Controlos de segurança físicos: refere-se proteção do espaço, no caso a sala dos servidores da universidade de Coimbra, onde a base de dados está.

Controlos lógicos: refere-se à proteção de software, no caso cifragem, backups, controlo de acesso lógico, entre outros.

Controlo organizacionais: referem-se às pessoas e a política serve para gerir o comportamento dos voluntários, e assegurar o cumprimento da lei (ou seja, não partilhar dados dos participantes com terceiros).

4.1 - Mitigação de Riscos de Comunicação e Servidor

A transferência e o armazenamento de dados dos participantes, representam as fases mais vulneráveis do projeto. Para mitigar os riscos foram implementadas os seguintes controlos lógicos e organizacionais:

Cifragem de Dados em Trânsito: Para reduzir a ameaça de interceção de comunicações (eavesdropping) em redes inseguras, como Wi-Fi públicas, todos os dados transmitidos entre a aplicação móvel e os servidores da universidade são cifrados. Esta medida assegura confidencialidade e impede a modificação indesejada da informação durante a transmissão de dados.

Controlo de Acesso lógico aos Servidores: Para garantir a segurança da base de dados central, o projeto aplica uma rigorosa de restrição de privilégios. Na prática, isto significa que o acesso aos servidores é restrito a equipa responsável pelo projeto. Desta forma, cria-se uma barreira sólida que protege a informação dos participantes tanto contra ciberataques externos, como contra acessos indevidos por parte de elementos internos.

Gerenciamento de Violações de Dados Pessoais: Para que qualquer imprevisto, perda de dados ou “roubo” de informação do voluntário seja resolvido, o projeto segue um plano que orienta uma resposta rápida. Para travar o problema de imediato, estas medidas protegem os participantes e garantem que todas as regras de transparência sejam cumpridas rigorosamente.

Uso de Protocolos TLS/HTTPS: Implementamos ligações seguras em todas as comunicações. Isto garante que, mesmo que alguém intercepte o sinal Wi-Fi, os dados apareçam como um código indecifrável, protegendo a localização e o e-mail em tempo real.

Implementação de VPN (Virtual Private Network): O acesso ao servidor não é feito diretamente pela Internet. A equipa tem de se ligar primeiro a uma rede privada segura (VPN), o que "esconde" o servidor de ataques externos e hackers.

Autenticação Forte (Login): exigir credenciais robustas para os investigadores. Isto evita que acessos não autorizados aconteçam por via de passwords fracas ou roubo de contas.

4.2 - Proteção de Dados em Repouso e Anonimização

Para manter a informação segura nos servidores, é aplicado medidas de proteção em repouso. Para proteger a identidade dos participantes, utilizamos técnicas de anonimização que transformam os dados em estatísticas e para evitar perdas por falhas técnicas, realizamos *backups* frequentes de todo o trabalho.

Anonimização do Dataset: Esta medida visa neutralizar o risco de reidentificado (linkage attacks) e proteger a intimidade dos voluntários contra a exposição de hábitos pessoais. Ao eliminar o vínculo direto entre os dados comportamentais (como a localização e os aplicativos instalados) e identidade do participante (email), o projeto certifica que a privacidade se mantenha inviolável, mesmo quando os dados são consultados por investigadores externos ou terceiros.

Cópias de Segurança (*Backups*): Para evitar que falhas de hardware, ataques externos ou erros humanos comprometam os dados, o projeto realiza rotinas rigorosas de *backups*. Esta é a principal rede de segurança para garantir que o esforço das campanhas não se perde, mantendo todo o histórico de informação protegido e sempre acessível.

Pseudonimização do E-mail e Isolamento de Chaves: O e-mail do participante é transformado num identificador e guardado numa tabela isolada das localizações. Assim, mesmo que alguém acesse a base de dados de GPS, não consegue saber a quem pertence aquele rasto sem a "chave" que está protegida noutro local.

Hashing de Nomes de Aplicações: Em vez de guardarmos "Tinder" ou "WhatsApp" em texto limpo, transformamos o nome da app num código único (hash). Isto permite-nos saber que o utilizador usou a mesma app várias vezes para fins estatísticos, mas impede que qualquer pessoa leia o nome real da aplicação na base de dados.

Cifragem da Base de Dados em Repouso: Todos os ficheiros guardados nos discos do servidor estão cifrados. Se os discos forem fisicamente roubados ou copiados sem autorização, a informação permanece ilegível sem a chave mestre do sistema.

4.3 - Tabela de Mitigação de Riscos Específicos

A tabela seguinte ilustra os principais riscos de segurança previstos e as respetivas defesas que aplicámos para proteger o projeto e garantir a segurança dos dados.

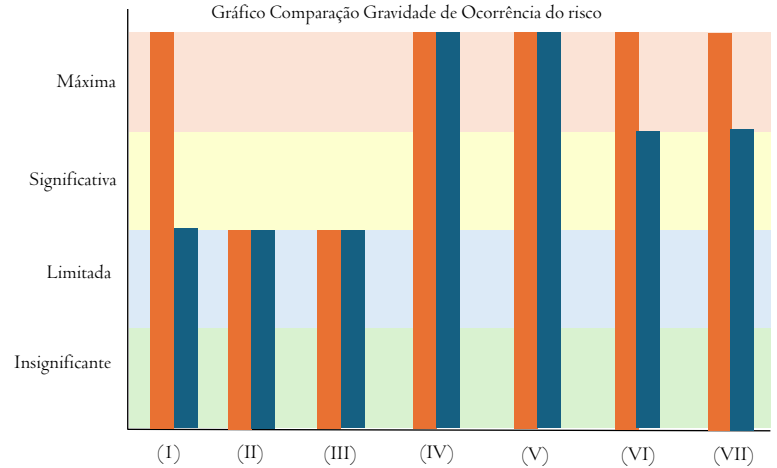
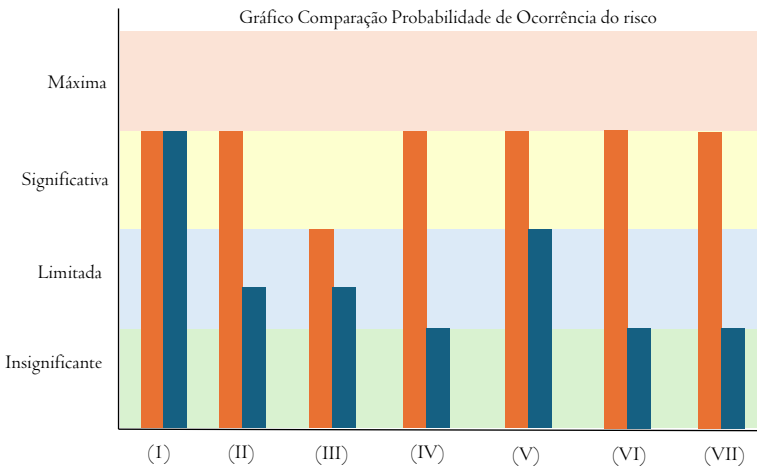
Risco Identificado	Medidas Corretivas (Controlos)
Acesso Ilegítimo aos Dados	Cifragem de dados em trânsito; Controlo de acesso lógico; Anonimização do <i>dataset</i>
Modificação Indesejada	Cifragem de dados em trânsito; Controlo de acesso lógico; Gerenciamento de violações de dados
Desaparecimento dos Dados	Cópias de segurança (<i>backups</i>); Gerenciamento de violações de dados

Fuga de dados por intercepção (<i>eavesdropping</i>)	Cifragem de todas as comunicações entre o telemóvel e o servidor; Uso de ligações seguras (TLS/HTTPS).
Acesso não autorizado ao servidor/dados	Usar uma VPN para acesso restrito à equipa; Exigência de autenticação (login forte) para a equipa; Servidor não exposto diretamente à Internet.
Reidentificação de dados em repouso	Pseudonimização do endereço de e-mail; Isolamento da tabela de chaves de identificação; Manter a base de dados cifrada.
Fuga de informações sensíveis	Transformar nomes de apps em códigos (hashing); Guardar no servidor apenas os códigos, garantindo que o nome real nunca é registado.

5. Avaliação Pós-Medidas Corretivas

Risco	Cenário Inicial		Cenário Melhorado		Observações
	Prob.	Grav.	Prob.	Grav.	
Acesso Ilegítimo aos Dados	S	M	S	L	A probabilidade de ocorrer manteve-se, mas a cifragem e a pseudonimização reduziram drasticamente a gravidade de uma potencial exposição
Modificação Indesejada	S	L	I/L	L	Tanto a probabilidade como a gravidade diminuíram. O isolamento da rede dificulta a probabilidade do ataque, e os <i>backups</i> minimizam a gravidade do impacto.
Desaparecimento dos Dados	L	L	I/L	L	Tanto a probabilidade como a gravidade diminuíram. As medidas de contingência e as cópias de segurança tornaram a perda definitiva num risco residual.
Fuga de dados por intercepção (<i>eavesdropping</i>)	S	M	I	M	A cifragem TLS/HTTPS torna os dados ilegíveis para qualquer intermediário, reduzindo a probabilidade de leitura para insignificante, embora a gravidade dos dados brutos se mantenha máxima.
Acesso não autorizado ao servidor/dados	S	M	L	M	A VPN e a autenticação forte escondem o servidor da internet pública e restringem o acesso, baixando a probabilidade para limitada ao impedir ataques externos diretos.
Reidentificação de dados em repouso	S	M	I	S	Ao isolar os e-mails e usar chaves de identificação protegidas, a probabilidade de cruzar identidades torna-se insignificante, além de que, mesmo que alguém entrasse na base de dados, já não conseguiria “vincular” os dados
Fuga de informações sensíveis	S	M	I	S	O <i>hashing</i> substitui nomes reais por códigos irreversíveis, fazendo com que a probabilidade de ler nomes de apps seja insignificante e a gravidade do impacto desça para limitada, dado que mesmo com acesso aos códigos de hashing, não seria possível extrair informação.

Legenda: M (Máxima) S (Significativa) L (Limitada) I (Insignificante);



Legenda:

(I) Acesso Ilegítimo aos Dados

(II) Modificação Indesejada dos Dados

(III) Desaparecimento dos Dados

(IV) Fuga de Dados por *Eavesdropping*

(IV) Acesso Não Autorizado aos dados/servidor

(V) Reidentificação (linkage de dados em repouso)

(VI) Fuga de Informações Sensíveis

Antes

Depois

6. Conclusão

Um sistema robusto de gestão de privacidade é fundamental para projetos de investigação como o COP-MODE, que recolhem e processam diversos tipos de Informação de Identificação Pessoal (PII). Através de uma Avaliação de Impacto sobre a Privacidade (PIA), identificámos riscos críticos, tais como o acesso ilegítimo aos dados, a modificação indesejada, o desaparecimento de dados, a interceção de comunicações (*eavesdropping*) e a fuga de informações sensíveis.

Para neutralizar estas ameaças, implementamos medidas para mitigar estes riscos, com foco na cifragem, anonimização de dados, gerenciamento de violação de dados e cópias de segurança. O uso de técnicas criptográficas é essencial para proteger os dados tanto em trânsito como em repouso.

Em suma, estas medidas corretivas propostas e implementadas pela nossa equipa criam uma estrutura sólida para proteger a privacidade dos participantes. Contudo, a avaliação contínua de riscos e o ajuste das práticas de segurança são essenciais para manter um ambiente seguro e que respeite a privacidade durante a recolha e o processamento de dados.

7. Bibliografia

- Site do COP-MODE: <https://cop-mode.dei.uc.pt/>
- William Stallings, "Information Privacy Engineering and Privacy by Design", Pearson Addison-Wesley, 2020
- Ferramenta CNIL, versão 3.03
- Statistics New Zealand, "Privacy Impact Assessment for the Integrated Data Infrastructure", 2012. <https://www.stats.govt.nz/assets/Uploads/Retirement-of-archive-website-project-files/Privacy-Impact-Assessment/Privacyimpact-assessment-for-the-Integrated-Data-Infrastructure/idi-privacy-impact-assessment.pdf>
- E.U. Smart Grid Task Force, "Data Protection Impact Assessment Template for Smart Grid and Smart Metering Systems", September 2018, https://energy.ec.europa.eu/system/files/2018-09/dpia_for_publication_2018_0.pdf

8. Uso de IA

A IA foi maioritariamente usada para esclarecimento de dúvidas, como no uso da ferramenta CNIL. Além disso, foi também usada para aperfeiçoamento do trabalho, isto é, como melhorar a organização, aspeto geral e algum vocabulário.

